Resilienz als Organisationsfähigkeit

Vorlesungsskript · Sitzung 5 · Grundlagen der Resilienz

Prof. Dr. Dirk Loomans

29. September 2026

Vorbemerkung: Dieses Skript dient als Vorlesungsbegleitung und erhebt keinen akademischen Anspruch. Dennoch kann es bei der Klausurvorbereitung hilfreich sein. Kommentare und Verbesserungsvorschläge gerne an den Autor über dirk.loomans@hs-mainz.de.

Die mit „Hinweis zur Aktualität“ und „Ergänzung zur Vorlesung“ markierten Kästen sowie die Abbildungen wurden bei der Überführung ins Quarto-Projekt ergänzt. Der übrige Text entspricht dem Skript aus dem Wintersemester 2025/26; korrigiert wurden nur Tipp- und Umbruchfehler.

Kapitel 1 – Einleitung und Zielsetzung der Sitzung

In den vorangegangenen Sitzungen wurde Resilienz vor allem **technisch** betrachtet: Wie Systeme entworfen, redundant aufgebaut und wiederherstellbar gemacht werden können, um trotz Angriffen oder Störungen funktionsfähig zu bleiben. Diese fünfte Sitzung verschiebt nun den Fokus von der Technik auf die **Organisation**, also auf die Fähigkeit von Menschen und Strukturen, in Krisen **koordiniert, informiert und entscheidungsfähig** zu handeln.

Während technische Resilienz das „Wie überlebt das System?“ adressiert, fragt organisationale Resilienz:

„Wie überlebt die Organisation – und bleibt dabei handlungsfähig?“

In komplexen Cyber-Security-Umgebungen entscheidet nicht allein der technische Zustand über Erfolg oder Scheitern, sondern vor allem **Kommunikation, Entscheidungswege und Rollenbewusstsein**.

Organisationale Resilienz ist somit das Bindeglied zwischen Technologie, Management und Kultur.

Die Sitzung verfolgt drei Lernziele:

1. **Verstehen**, was unter organisationaler Resilienz nach ISO 22316 zu verstehen ist (Fähigkeit, Störungen vorherzusehen, zu bewältigen und daraus zu lernen).
2. **Erkennen**, welche Rollen, Prozesse und Kommunikationsmuster Resilienz fördern oder behindern.
3. **Anwenden**, wie Organisationen durch Training, Governance und Lernkultur ihre Widerstandsfähigkeit institutionalisieren können.

Damit schließt die Sitzung die inhaltliche Lücke zwischen „technischer Robustheit“ und „sozialer Handlungsfähigkeit“.

Beide Dimensionen sind komplementär: Nur wenn Systeme und Menschen gleichermaßen vorbereitet sind, entsteht echte Cyber-Resilienz.

Kapitel 2 – Von der technischen zur organisationalen Resilienz

Technische Resilienz bildet die Grundlage moderner IT-Systeme. Sie basiert auf **Redundanz**, **Diversität**, **Wiederherstellbarkeit** und **Adaptivität** – also auf architektonischen Eigenschaften, die sicherstellen, dass Systeme Störungen absorbieren oder kompensieren können. Doch Technik allein erzeugt noch keine Resilienz. Sie schafft nur das **Potenzial**, resilient zu sein.

Organisationale Resilienz beschreibt dagegen die Fähigkeit, dieses Potenzial **gezielt zu aktivieren** – insbesondere unter Stress, Zeitdruck oder Informationsunsicherheit. Hier entscheidet nicht mehr die Architekturqualität, sondern die **Reaktionsfähigkeit der Organisation**:

Wer erkennt den Vorfall? Wer informiert wen?

Wer entscheidet, was getan wird – und in welcher Reihenfolge?

2.1 Unterschiedliche Logiken von Technik und Organisation

Technische Resilienz und organisationale Resilienz folgen unterschiedlichen Logiken. Während technische Resilienz deterministisch und planbar ist, zielt organisationale Resilienz auf menschliches Verhalten, Entscheidungsfähigkeit und Kommunikation unter Unsicherheit.

In der Praxis wird Resilienz nur dann wirksam, wenn **beide Ebenen** zusammenspielen.

Aspekt	Technische Resilienz	Organisationale Resilienz
Steuerungslogik	Deterministisch, automatisiert	Adaptiv, situativ
Fokus	Systeme und Prozesse	Menschen, Rollen, Kommunikation
Nachweis	Monitoring, Failover-Tests	Übungen, Entscheidungswege, Lernfähigkeit
Zielgröße	System bleibt funktionsfähig	Organisation bleibt handlungsfähig

Fachberichte und Leitfäden zum Incident Response zeigen, dass **organisatorische Defizite** häufig die Ursache für unzureichende Reaktionsfähigkeit sind.

Der *NIST Computer Security Incident Handling Guide* (SP 800-61 Rev. 2, 2012) betont, dass die Effektivität des Incident Handling „maßgeblich von klaren Zuständigkeiten, Kommunikationswegen und geübten Prozessen“ abhängt – nicht primär von der eingesetzten Technik.

Auch ENISA weist in ihren *Good Practice Guides for Incident Management* darauf hin, dass die größten Schwächen bei Eskalationen typischerweise in **Rollenunklarheit und fehlender Abstimmung zwischen Teams** liegen.

SANS-Umfragen unter Incident-Response-Teams (z. B. SANS 2024 IR Survey) zeigen ebenfalls, dass „coordination“ und „communication“ zu den am häufigsten genannten Hindernissen zählen.

Daraus ergibt sich ein klares Muster:

Technische Schutzmaßnahmen sind notwendig, aber nicht hinreichend.

Ohne funktionierende Entscheidungslogik, Kommunikationsdisziplin und Übung bleiben selbst hochverfügbare Systeme im Krisenfall wirkungslos.

(Quellen: NIST SP 800-61 Rev. 2 (2012); ENISA Good Practice Guide for Incident Management (2021); SANS Incident Response Survey (2024).)

> **i** Hinweis zur Aktualität
>
> NIST SP 800-61 Rev. 2 (2012) wurde im April 2025 durch Revision 3 ersetzt, die Incident Response am NIST CSF 2.0 ausrichtet [1]. Titel und Jahr der hier genannten ENISA- und SANS-Quellen sind nicht geprüft. Siehe Quellen, Hinweis 6, Quellen, Hinweis 10.

2.2 Die Rolle der Kommunikation und Entscheidungslogik

Technik kann Redundanz schaffen – aber **nicht Kommunikation ersetzen**. Die Fähigkeit, in Krisen klar zu kommunizieren, priorisieren und Entscheidungen zu treffen, ist das soziale Äquivalent zu technischer Fehlertoleranz. In diesem Sinne wirkt Organisationale Resilienz wie ein „**soziales Redundanzsystem**" – sie fängt menschliche und informationelle Unsicherheiten ab.

Kommunikation wird dadurch selbst zu einem **Resilienzfaktor**: Wenn Informationen zu spät, unvollständig oder falsch verstanden werden, können auch perfekte technische Systeme nicht effektiv reagieren. Daher ist Kommunikation keine Nebentätigkeit, sondern **Teil der Resilienzarchitektur**.

2.3 Organisational Resilience als Verhaltensdisziplin

ISO 22316 definiert organisationale Resilienz als die Fähigkeit, „Störungen vorherzusehen, sich darauf vorzubereiten, darauf zu reagieren und sich daran anzupassen, um in einem sich verändernden Umfeld zu überleben und zu gedeihen."

Damit wird Resilienz zu einer **Verhaltensdisziplin**. Sie entsteht nicht in der Dokumentation, sondern in der Übung:

Menschen müssen trainiert werden, wie Systeme reagieren – nicht nur wissen, dass sie es sollen.

Kapitel 3 – Der Resilienzzyklus und seine organisatorische Umsetzung

Der Resilienzzyklus beschreibt den wiederkehrenden Prozess, mit dem eine Organisation Störungen erkennt, bewältigt und daraus lernt.

Er umfasst die Phasen **Detection**, **Response**, **Recovery** und **Adapt**, die – ähnlich wie der PDCA-Zyklus – ein kontinuierliches Lernen ermöglichen. Während der PDCA-Ansatz (Plan–Do–Check–Act) auf Qualitätsmanagement und ISO 27001 zielt, fokussiert der Resilienzzyklus auf **reaktive und adaptive Fähigkeiten im Krisenfall**.

3.1 Detection – Wahrnehmungsfähigkeit als Startpunkt

Resilienz beginnt mit der Fähigkeit, Abweichungen frühzeitig zu erkennen. Detection bedeutet nicht nur technisches Monitoring (z. B. Logfiles, IDS), sondern auch die **menschliche Wahrnehmung** ungewöhnlicher Situationen – etwa bei Nutzeranfragen, Performanceeinbrüchen oder untypischem Kommunikationsverhalten. Eine Organisation ist nur so resilient wie ihre Fähigkeit, Signale richtig zu interpretieren.

- **Technische Dimension:** Sensorik, SIEM, Anomalieerkennung
- **Organisationale Dimension:** Meldekultur, Informationsaufnahme, Priorisierung
- **Herausforderung:** Informationsrauschen vs. Aufmerksamkeit

Ziel ist nicht absolute Überwachung, sondern **zielgerichtete Wahrnehmung**.

3.2 Response – Koordinierte Reaktion unter Unsicherheit

In der Response-Phase entscheidet die Organisation, **wer was wann tut**. Sie umfasst Sofortmaßnahmen, Schadensbegrenzung und interne Kommunikation. Zentral ist die **Eskalationsfähigkeit**: Ein Incident darf nicht an individuellen Grenzen hängen bleiben.

Das erfordert klare Rollen (z. B. Incident Commander), Kommunikationsroutinen und Entscheidungskompetenzen.

Ein häufiges Problem: Teams reagieren technisch korrekt, aber **unkoordiniert**, weil niemand das Gesamtbild verantwortet. Organisationale Resilienz zielt daher auf Synchronisation: Alle Beteiligten handeln entlang einer gemeinsamen Lageeinschätzung.

3.3 Recovery – Wiederherstellung der Handlungsfähigkeit

Recovery bedeutet mehr als „Systeme wieder hochfahren". Es geht um das **Wiederherstellen organisationaler Funktion** – z. B. Entscheidungsfähigkeit, Kommunikationsflüsse und Prioritätensteuerung. Technische Recovery ohne organisatorische Priorisierung führt oft zu suboptimalen Ergebnissen (etwa Wiederanlauf unwichtiger Systeme vor kritischen Prozessen).

Daher muss die Recovery-Phase

- Prioritäten nach Geschäftsrelevanz (Business Impact) berücksichtigen,
- Kommunikation mit Stakeholdern sichern,
- und psychologische Belastung im Team einbeziehen.

Eine gute Wiederherstellung ist **koordiniert, nicht chaotisch**.

3.4 Adapt – Lernen und Verbessern

Der letzte Schritt ist der entscheidende: **Lernen aus Störungen**. Nur durch Reflexion und Anpassung wird Resilienz nachhaltig. Der Lernprozess erfolgt systematisch über *After-Action Reviews*, *Post-Mortems* oder *Lessons Learned*-Workshops.

Hier werden nicht Schuldige gesucht, sondern strukturelle Ursachen analysiert. Das Ergebnis fließt in Schulungen, Playbooks, Governance und Architektur zurück.

Adaptivität ist damit das Bindeglied zwischen Incident Handling und Organisationsentwicklung.

Eine Organisation, die nach jedem Vorfall etwas besser wird, ist per Definition resilient.

3.5 Zusammenhang mit etablierten Frameworks

- **ISO/IEC 27035**: Definiert den Lebenszyklus des Incident Handling
- **BSI-200-4**: Bewertet Resilienz anhand von Reifegraden der Reaktionsfähigkeit
- **NIST SP 800-160 Vol. 2**: Koppelt Resilienz an Fähigkeiten (*capabilities*)
- **ISO 22316**: Überträgt diese Denkweise auf die gesamte Organisation

Damit ist der Resilienzzyklus kein theoretisches Konzept, sondern **ein verbindendes Prinzip zwischen Technik, Organisation und Kultur**.

Kapitel 4 – Rollen, Verantwortung und Entscheidungslogik in Krisenorganisationen

Organisationale Resilienz lebt von Klarheit.

In einer Krise entstehen parallel technischer, kommunikativer und strategischer Handlungsdruck.

Je unklarer Rollen und Entscheidungswege sind, desto größer wird das Risiko einer **Reaktionsparalyse** — der Zustand, in dem alle etwas tun, aber niemand die Richtung vorgibt.

Resilienz verlangt daher nicht nur Strukturen, sondern auch **Entscheidungslogik**.

4.1 Strukturprinzip: Rollen statt Personen

Effektive Krisenorganisationen definieren Rollen **unabhängig von Personen**. Nicht wichtig ist, *wer anwesend* ist, sondern *wer welche Rolle* ausfüllt. Das verhindert Abhängigkeit von Einzelpersonen und sorgt für Skalierbarkeit in 24/7-Betrieben.

Typische Rollen im Resilienzkontext:

Rolle	Hauptverantwortung
CISO	Strategische Gesamtverantwortung, Kommunikation mit Geschäftsleitung
Incident Commander	Operative Leitung des Incident-Response-Teams, Priorisierung
Technical Lead / IT Operations	Analyse, Containment, Wiederherstellung
Business Continuity Manager	Koordination mit Fachbereichen, Priorisierung kritischer Prozesse
Kommunikation / PR	Interne und externe Informationssteuerung
Legal / Datenschutz	Bewertung regulatorischer Meldepflichten (z. B. DSGVO Art. 33)
Management Board	Freigabe von Ressourcen, Risikoakzeptanz, externe Vertretung

Ziel: Jede Funktion weiß, was sie entscheidet, nicht nur was sie tut.

4.2 Entscheidungslogik in Krisen

In Krisen gelten andere Regeln als im Normalbetrieb. Der normale Linienweg („Abteilungsleiter – Bereichsleiter – Geschäftsführung“) ist zu langsam.

Resiliente Organisationen verfügen über **vordefinierte Eskalationspfade** mit Entscheidungskompetenz auf Zeit.

Ein bewährtes Modell ist das **Incident Command System (ICS)**, ursprünglich aus dem Katastrophenschutz:

- Klare Hierarchie mit taktischer Führung (Incident Commander)
- Temporäre Rollen, die sich je nach Lage erweitern oder reduzieren
- Entscheidungsgewalt nach Lage, nicht nach Rang

Diese Logik lässt sich auf Cyber-Resilienz übertragen: Die „Command“-Ebene priorisiert, die „Operations“-Ebene handelt, die „Support“-Ebene dokumentiert und kommuniziert. So wird Chaos in **koordiniertes Handeln** überführt.

4.3 Prinzipien wirksamer Führungsstrukturen

1. **Unity of Command** – Jeder Mitarbeitende berichtet in der Krise an genau *eine* Führungsperson.
2. **Span of Control** – Eine Führungskraft koordiniert maximal 5–7 Personen gleichzeitig.
3. **Delegation of Authority** – Entscheidungen dürfen an der niedrigsten sinnvollen Ebene getroffen werden.
4. **Documentation & Traceability** – Jede Entscheidung ist nachvollziehbar protokolliert.

5. **Role Rotation & Training** – Rollen müssen regelmäßig trainiert und vertretbar sein.

Diese Prinzipien sind in internationalen Frameworks (z. B. NIST SP 800-61 r2, ISO 22320) verankert und bilden das Rückgrat resilienter Führungsmodelle.

4.4 Psychologische Dimension: Entscheidung unter Stress

Forschung aus der Kognitionspsychologie zeigt, dass Stress, Informationsüberlastung und Zeitdruck die Entscheidungsqualität drastisch reduzieren.

In diesem Zustand greifen Menschen auf Heuristiken zurück – also auf erlernte Muster. Darum ist **Training** entscheidend:

Nur geübte Abläufe ermöglichen Entscheidungen, wenn rationale Abwägung nicht mehr möglich ist.

Organisationale Resilienz zielt daher darauf ab, Entscheidungen **vorzubereiten**, nicht nur zu treffen.

Playbooks, Priorisierungslisten und Entscheidungsdiagramme (Decision Trees) schaffen Orientierung in Momenten maximaler Unsicherheit.

4.5 Verbindung zu Governance und Compliance

Rollen- und Entscheidungsmodelle sind nicht nur praktisch, sondern auch regulatorisch relevant. Standards wie **ISO/IEC 27035**, **BSI-200-4** und **NIS-2-Richtlinie** fordern explizit den Nachweis strukturierter Incident-Response-Organisationen inklusive dokumentierter Verantwortlichkeiten, Meldewege und Eskalationslogiken.

Damit wird Führungsfähigkeit zu einem **Prüfkriterium der Resilienz** – vergleichbar mit Backup- oder Recovery-Tests auf technischer Ebene.

Kernaussage:

In Krisen entscheidet Organisation über Technik. Rollen, Eskalationswege und Entscheidungsklarheit sind die wahren „Redundanzen" menschlicher Resilienz.

Kapitel 5 – Kommunikation als Resilienzfaktor

5.1 Kommunikation als Schlüssel organisationaler Handlungsfähigkeit

In nahezu jeder Incident-Analyse zeigt sich: Fehler in der Kommunikation sind häufiger als Fehler in der Technik. Kommunikation entscheidet darüber, **wie schnell** Informationen fließen, **wie klar** sie verstanden werden und **wie koordiniert** gehandelt wird. Organisationale Resilienz beruht deshalb auf einer Kommunikationskultur, die in Stresssituationen **präzise, überprüfbar und empathisch** funktioniert.

Ziel resilienzorientierter Kommunikation ist es,

- Informationsverluste und Fehlinterpretationen zu vermeiden,
- Entscheidungsprozesse zu beschleunigen,
- und Vertrauen trotz Unsicherheit aufrechtzuerhalten.

ENISA, NIST SP 800-61 r2 und ISO 22316 nennen Kommunikation ausdrücklich als **kritische Fähigkeit innerhalb des Resilienzzyklus**.

Ein funktionierendes Kommunikationssystem verbindet technische, operative und strategische Ebenen.

5.2 Prinzipien effektiver Krisenkommunikation

In Krisen gilt eine einfache Regel:

„Eine Information ist nur dann nützlich, wenn sie verstanden, bestätigt und geteilt wurde."

Daraus ergeben sich vier Leitprinzipien (nach CCCC-Modell):

1. **Clear** – Aussage ist eindeutig und frei von Mehrdeutigkeit.
2. **Concise** – Kürze statt Detailüberlastung.
3. **Confirmed** – Empfänger bestätigt Verständnis („Readback“).
4. **Coordinated** – Alle sprechen auf Basis derselben Lageeinschätzung.

Diese Prinzipien müssen **trainiert**, nicht nur definiert werden. Sie wirken wie ein Kommunikationsprotokoll: Je öfter geübt, desto stabiler im Ernstfall.

5.3 Exkurs: Das Kommunikationsmodell nach Schulz von Thun

Der Psychologe **Friedemann Schulz von Thun** beschreibt in seinem Modell „Vier Seiten einer Nachricht“ die Mehrdimensionalität jeder Kommunikation:

1. **Sachinhalt** – Worüber informiere ich?
2. **Selbstoffenbarung** – Was gebe ich von mir preis?
3. **Beziehung** – Was halte ich vom Gegenüber?
4. **Appell** – Was möchte ich erreichen?

Gerade in Krisen wird diese Komplexität sichtbar. Eine scheinbar sachliche Aussage wie

„Der Server ist schon wieder down.“

kann gleichzeitig Genervtheit (Selbstoffenbarung), Vorwurf (Beziehung) und Handlungsaufforderung (Appell) transportieren.

In Stresssituationen hören Menschen häufig **auf der falschen Ebene** – etwa als persönlichen Angriff statt technische Meldung.

Das Modell sensibilisiert Teams, auch unter Druck **metakommunikativ zu denken**: Was sende ich wirklich? Was empfängt mein Gegenüber?

Merksatz: „Resilienz in Kommunikation heißt: auf allen vier Ohren bewusst sprechen und hören.“

5.4 Kommunikationsübung: Vier Seiten einer Nachricht

Ziel: Bewusstsein für Mehrdeutigkeit und Fehlinterpretationen schärfen.

Aufgabe:

Analysieren Sie in 3er-Gruppen die Aussage:

„Warum habt ihr das Backup noch nicht eingespielt?“

Diskutieren Sie:

- Welche Botschaften liegen auf den vier Ebenen?
- Wie könnte dieselbe Aussage *resilienter* formuliert werden?
- Welche Missverständnisse entstehen, wenn Empfänger nur eine Ebene hören?

Beispielhafte Auswertung:

Ebene	Interpretation
Sachinhalt	Das Backup wurde noch nicht eingespielt.

Ebene	Interpretation
Selbstoffenbarung	Ich bin gestresst / unter Druck.
Beziehung	Ich zweifle an eurer Kompetenz.
Appell	Bitte handelt jetzt sofort.

Alternative Formulierung:

„Wie ist der Stand beim Backup-Restore? Können wir gemeinsam priorisieren?“

Diese Übung verdeutlicht, dass Kommunikation **selbst ein Resilienzprozess** ist – je klarer, respektvoller und bewusster sie erfolgt, desto stabiler bleibt die Organisation in der Krise.

5.5 Verbindung zu Incident-Management und Governance

Gute Kommunikation ist in internationalen Standards verankert:

- **NIST SP 800-61 r2** fordert definierte Kommunikationskanäle und Ansprechpartner.
- **ENISA Incident Management Guide** empfiehlt Kommunikations-Playbooks und regelmäßige Testübungen.
- **BSI-200-4** bewertet Kommunikationsprozesse als Teil des Reifegradmodells für Resilienz.

Damit ist Kommunikation kein „Soft Skill“, sondern ein **organisatorisches Kontrollziel** und ein messbarer Faktor im Resilienz-Audit.

Kernaussage:

Organisationale Resilienz beginnt mit kommunikativer Klarheit. Wer unter Stress klar und respektvoll kommunizieren kann, reduziert Eskalationen, stärkt Vertrauen und verkürzt Recovery-Zeiten.

Kapitel 6 – Übungs- und Trainingskultur als Fundament organisationaler Resilienz

Technische Systeme werden regelmäßig getestet – Organisationen oft nicht. Doch Resilienz ist kein theoretisches Konzept, sondern eine **praktische Fähigkeit**. Erst durch Training entsteht die Verhaltenssicherheit, die in Krisen benötigt wird. Ohne Übung bleibt jede noch so gute Incident-Response-Policy ein Papierdokument.

Organisationale Resilienz verlangt daher eine **institutionalisierte Trainingskultur**, in der Fehler als Lernchancen gelten und Szenarien bewusst durchgespielt werden.

6.1 Formen des Resilienztrainings

a) Tabletop-Übungen (TTX)

Planspiele mit fiktiven, aber realistischen Szenarien. Ziel: Kommunikations- und Entscheidungsfähigkeit testen. TTX eignen sich für Management- und Querschnittsteams, da kein technischer Aufwand nötig ist.

b) Live-Simulationen

Technisch-operative Übungen, bei denen Systeme oder Services tatsächlich beeinträchtigt werden.

Ziel: Reaktionsgeschwindigkeit, Schnittstellen und Wiederanlaufprozesse real prüfen. Beispiele: Red-Team-Übungen, „Ransomware-Day“, Ausfall-Simulation eines Cloud-Providers.

c) After-Action Reviews (AAR) / Post-Mortems

Strukturierte Nachbesprechungen realer oder simulierter Incidents.

Fokus auf Ursache, Prozesslücken und Verbesserung – **nicht auf Schuldzuweisung**. Ergebnisse fließen zurück in Playbooks, Schulungen und Governance.

6.2 Messgrößen und Erfolgsindikatoren

Resilienz lässt sich nicht absolut messen, wohl aber **bewerten**. Typische Kennzahlen:

Metrik	Bedeutung
Time to Detect (TTD)	Wie schnell wird ein Incident erkannt?
Time to Decision (TTDec)	Wie schnell fällt eine handlungsleitende Entscheidung?
Time to Recover (TTR)	Wie lange dauert es, bis kritische Systeme wieder lauffähig sind?
Communication Efficiency Score	Verhältnis bestätigter zu gesendeten Meldungen
Exercise Frequency	Anzahl der durchgeführten Übungen pro Jahr

Diese Kennzahlen werden zunehmend Bestandteil von **BCM- und ISMS-Audits**. Sie machen Resilienz operationalisierbar und fördern kontinuierliche Verbesserung.

6.3 Organisatorische Verankerung

Eine nachhaltige Trainingskultur braucht:

- **Regelmäßigkeit:** mindestens zwei Tabletop-Übungen pro Jahr
- **Dokumentation:** strukturierte Lessons-Learned-Protokolle
- **Management-Teilnahme:** gelebte Vorbildfunktion
- **Evaluation:** standardisierte Bewertung (z. B. BSI-200-4 Reifegrad)

Training ist damit kein freiwilliges Zusatzprogramm, sondern Bestandteil des Resilienzmanagements nach ISO 22316 und ISO 22301.

6.4 Psychologische und kulturelle Dimension

Menschen lernen unter Stress nur das, was sie zuvor **trainiert** haben. Krisentraining hat daher auch eine emotionale Funktion:

Es reduziert Angst, fördert Teamkohäsion und schafft Vertrauen in die eigenen Fähigkeiten.

Ein Team, das regelmäßig übt, erlebt weniger Panik, wenn der Ernstfall eintritt. Resilienztraining ist somit zugleich **technische Probe und Kulturarbeit**.

6.5 Von der Übung zur Lernorganisation

Der eigentliche Mehrwert entsteht nicht während der Übung, sondern **danach** – im strukturierten Lernen aus Fehlern. Organisationen, die aus jedem Incident Erkenntnisse ziehen und diese institutionalisiert umsetzen, entwickeln sich zu *Learning Organizations* (nach Peter Senge).

Damit schließt sich der Resilienzzyklus:

Detection → Response → Recovery → Adapt. Der Schritt „Adapt“ ist im Kern nichts anderes als institutionalisiertes Lernen.

Kernaussage:

Resilienz entsteht durch Wiederholung, Reflexion und Anpassung. Eine Organisation, die regelmäßig übt und ehrlich aus Fehlern lernt, wird mit jedem Incident stärker – nicht schwächer

Kapitel 7 – Governance, Reifegrad und Messbarkeit organisationaler Resilienz

Resilienz ist kein Zufall, sondern Ergebnis von **strukturiertem Management**. Damit sie dauerhaft wirkt, muss sie in die **Governance-Architektur** einer Organisation eingebettet sein – also in Prozesse, Rollen, Verantwortlichkeiten und Berichterstattung. Nur was gemessen, überprüft und verbessert wird, kann wachsen.

Governance macht aus spontaner Reaktion **nachhaltige Fähigkeit**.

7.1 Resilienz in Managementsystemen

Resilienz ist kein isoliertes System, sondern eine **Querschnittsfunktion** über bestehende Managementsysteme hinweg:

Managementsystem	Bezug zur Resilienz
ISMS (ISO/IEC 27001)	Schafft Struktur für Informationssicherheit und Incident Management
BCMS (ISO 22301)	Fokussiert auf Kontinuität kritischer Geschäftsprozesse
Risk Management (ISO 31000)	Identifiziert und bewertet Bedrohungen
Crisis Management (ISO 22320)	Beschreibt Entscheidungs- und Kommunikationsstrukturen im Ereignisfall
Resilience Management (ISO 22316)	Verbindet die genannten Systeme zu einer adaptiven Gesamtstruktur

Diese Integration sorgt dafür, dass Resilienz **nicht als zusätzliches System**, sondern als *übergreifendes Steuerungsprinzip* verstanden wird.

7.2 Governance-Prinzipien der Resilienz

Eine belastbare Resilienz-Governance beruht auf fünf Kernprinzipien:

1. **Verantwortung** – klare Zuweisung von Rollen und Eskalationsrechten
2. **Transparenz** – nachvollziehbare Entscheidungs- und Kommunikationswege
3. **Partizipation** – Einbindung aller Ebenen (Top-down und Bottom-up)
4. **Kontinuität** – Regelmäßige Überprüfung und Aktualisierung
5. **Lernfähigkeit** – Feedback-Mechanismen aus Incidents und Übungen

Diese Prinzipien spiegeln sich sowohl in **ISO 22316 (Organizational Resilience)** als auch im **BSI-Standard 200-4** wider, der Resilienz als Erweiterung von BCM versteht.

7.3 Reifegradmodelle (Maturity Models)

Um den Stand organisationaler Resilienz zu bewerten, werden **Reifegradmodelle** eingesetzt.

Sie ermöglichen eine objektive Standortbestimmung und Priorisierung von Verbesserungen.

Beispielhafte Skala (nach BSI-200-4 und ISO 22316):

Reifegrad	Beschreibung
Level 1 – Ad hoc	Keine systematische Resilienzpraxis, reaktive Reaktionen
Level 2 – Initialisiert	Erste Prozesse und Verantwortlichkeiten definiert
Level 3 – Etabliert	Verfahren sind dokumentiert, regelmäßig geübt
Level 4 – Gemanagt	Resilienz ist messbar, integriert und auditierbar
Level 5 – Optimiert	Kontinuierliche Verbesserung und organisationsweite Lernkultur

Der Reifegrad zeigt, **wo die Organisation steht** – und wohin sie sich entwickeln kann. Er dient zugleich als Kommunikationsinstrument gegenüber Management, Audit und Aufsicht.

> ℹ Hinweis zur Aktualität
>
> Die finale Fassung des BSI-Standards 200-4 (Mai 2023) unterscheidet drei Stufen: Reaktiv-BCMS, Aufbau-BCMS und Standard-BCMS [2]. Die hier gezeigte fünfstufige Skala ist als allgemeines Reifegradmodell zu verstehen, nicht als Stufenmodell des Standards. Siehe Quellen, Hinweis 3.

7.4 Metriken und Kennzahlen

Resilienz ist schwer greifbar, aber durch Metriken **indirekt messbar**. Neben den technischen Kennzahlen (z. B. Time-to-Recover) kommen zunehmend **organisatorische Indikatoren** zum Einsatz:

Kennzahl	Aussage
Übungshäufigkeit / Jahr	Wie regelmäßig wird trainiert?
Implementierungsgrad Lessons Learned (%)	Wie viele Verbesserungsvorschläge werden umgesetzt?
Reaktionszeit Management-Entscheidung (min)	Wie schnell wird eine Freigabe erteilt?
Kommunikationslatenz	Zeit zwischen Ereigniserkennung und Erstinformation
Resilience Audit Score	Bewertungswert aus interner oder externer Prüfung

Solche Kennzahlen sind **nicht Selbstzweck**, sondern dienen der Steuerung und Rechenschaft.

Sie ermöglichen evidenzbasiertes Resilienzmanagement.

7.5 Audits und Nachweise

Viele Standards – etwa **ISO 22301, ISO/IEC 27035 und BSI-200-4** – fordern Nachweise über die Wirksamkeit der Resilienzmaßnahmen. Diese Nachweise umfassen u. a.:

- Protokolle von Übungen und Incidents
- Nachverfolgung von Lessons Learned
- Governance-Reports und Management Reviews

- Nachweise über Schulungen und Verantwortlichkeiten

Damit wird Resilienz **prüfbar und auditfähig**.

Für Cyber-Security-Organisationen ist das zugleich Teil der **Compliance-Pflicht** (z. B. NIS-2-Umsetzungsgesetz, § 30 BSIG).

7.6 Fazit: Steuerung von Resilienz als Führungsaufgabe

Governance verankert Resilienz im Führungssystem. Management schafft nicht Resilienz – es **ermöglicht** sie durch Struktur, Priorisierung und Ressourcen.

„Resilienz ist keine Projektaufgabe, sondern Führungsverhalten."

Nur wenn Resilienz gemessen, auditiert und gesteuert wird, entsteht aus Einzelmaßnahmen eine dauerhafte Fähigkeit. So wird aus der Fähigkeit zur Reaktion die **Kultur der Anpassung**.

Kapitel 8 – Fallbeispiel: Ransomware im Unternehmen

8.1 Szenariobeschreibung

Montagmorgen, 08:15 Uhr: Mehrere Mitarbeitende melden, dass Dateien auf Netzlaufwerken nicht mehr geöffnet werden können.

Auf den Bildschirmen erscheint eine Meldung mit Lösegeldforderung in Bitcoin. Der VPN-Zugang ist noch aktiv, Mails funktionieren, aber der Fileserver ist unzugänglich.

Die IT erkennt: Es handelt sich um einen **Ransomware-Angriff**.

Das Beispiel orientiert sich an realen Fällen aus der ENISA Threat Landscape (2024) und verdeutlicht, wie schnell technische Störungen zu organisatorischen Krisen eskalieren.

8.2 Ausgangsfragen für die Gruppenübung

1. Wer übernimmt die **Incident-Leitung** (Incident Commander)?
2. Welche Systeme oder Personen müssen **sofort informiert** werden?
3. Welche **Entscheidungen** sind in den ersten 30 Minuten kritisch?
4. Wie läuft die **interne und externe Kommunikation**?
5. Welche Priorität hat **Recovery** im Verhältnis zu **Forensik**?
6. Wann erfolgt die **Meldung an Aufsichtsbehörden** (DSGVO Art. 33 / NIS-2)?

Ziel dieser Übung ist es, zu erkennen, dass Resilienz nicht nur technische Robustheit, sondern vor allem **Entscheidungsrobustheit** bedeutet.

8.3 Typischer Verlauf eines Ransomware-Incidents

Phase	Beschreibung	Häufige Fehler
Detection	Erste Hinweise, z. B. unzugängliche Daten	Unterschätzung der Lage, verspätete Eskalation
Response	Eindämmung (z. B. Netzwerksegmentierung)	Fehlende Koordination, doppelte Maßnahmen
Communication	Interne / externe Information	Intransparenz, widersprüchliche Aussagen

Phase	Beschreibung	Häufige Fehler
Recovery	Wiederherstellung aus Backups	Keine Priorisierung, ungetestete Backups
Adapt / Lernen	Ursachenanalyse, Lessons Learned	Keine systematische Nachbereitung

Diese Matrix eignet sich hervorragend für die anschließende **Reflexion im Plenum**.

8.4 Organisatorische Herausforderungen

- **Eskalationsfähigkeit:** Wer darf Systeme abschalten oder Netzwerksegmente isolieren?
- **Kommunikationsführung:** Wie werden Mitarbeitende informiert, ohne Panik zu erzeugen?
- **Entscheidungslogik:** Wann ist die Geschäftsführung einzubeziehen?
- **Priorisierung:** Welche Systeme müssen zuerst wiederhergestellt werden?
- **Datenschutz und Recht:** Wann ist eine Meldepflicht ausgelöst?

Solche Fragen zeigen, dass organisationale Resilienz weit über IT-Kenntnisse hinausgeht: Sie betrifft Führung, Verantwortung und Vertrauen.

8.5 Typische Lessons Learned

1. **Playbooks sind Gold wert**, wenn sie aktuell und trainiert sind.
2. **Backups müssen getestet** werden – ein Backup ist nur so gut wie der letzte Restore.
3. **Kommunikation entscheidet** über Vertrauen nach innen und außen.
4. **Forensik und Wiederanlauf** müssen abgestimmt sein (keine Datenverluste durch Übereifer).
5. **Incident Reviews** sind keine Schuldzuweisung, sondern Lerngelegenheiten.

Diese Erkenntnisse verdeutlichen, dass jede Krise – richtig reflektiert – eine **Investition in zukünftige Resilienz** ist.

8.6 Reflexion: Was macht eine Organisation wirklich resilient?

Am Ende der Gruppenarbeit steht die Meta-Frage:

„Was hat in unserer Reaktion funktioniert – und was nicht?“

Durch diese Reflexion wird die Übung selbst Teil des Resilienzzyklus (*Adapt*). Die Studierenden lernen, wie Theorie (Rollen, Kommunikation, Prozesse) im praktischen Krisenszenario **konkret wirksam oder hinderlich** wird.

Kernaussage:

Resilienz zeigt sich nicht im Regelbetrieb, sondern in der Krise. Eine Organisation, die schnell, koordiniert und lernfähig reagiert, beweist ihre Widerstandsfähigkeit durch Handeln, nicht durch Dokumentation.

Kapitel 9 – Lernen, Kultur und psychologische Sicherheit in resilienten Organisationen

Technik und Prozesse sind planbar – menschliches Verhalten ist es nicht. Deshalb entscheidet letztlich **die Organisationskultur** darüber, ob Resilienz in der Praxis funktioniert. Eine Organisation, die aus Fehlern lernt statt sie zu vertuschen, entwickelt nachhaltige Anpassungsfähigkeit und Vertrauen.

Resilienz ist damit auch eine **Frage der Haltung**.

9.1 Von der Fehlervermeidung zur Lernkultur

Traditionell herrscht in vielen Unternehmen eine **Null-Fehler-Kultur**: Fehler gelten als Schwäche, Abweichungen als Mangel. In der Resilienzperspektive gilt jedoch das Gegenteil:

„Ein Fehler, aus dem nichts gelernt wird, ist der wahre Fehler."

Organisationale Resilienz verlangt deshalb eine **Lernkultur**, die Fehler systematisch analysiert, ohne Schuldzuweisungen. Statt „Who caused it?" lautet die Frage „What can we improve?"

Diese Denkweise entspricht dem Prinzip des *Continuous Improvement* aus dem PDCA-Zyklus und dem „Adapt"-Schritt des Resilienzzyklus.

9.2 Psychologische Sicherheit als Fundament

Der Begriff **Psychological Safety** (Amy C. Edmondson, Harvard Business School, 1999) beschreibt ein Arbeitsklima, in dem Menschen offen sprechen können, ohne Angst vor persönlichen Konsequenzen.

In resilienten Organisationen ist psychologische Sicherheit zentral: Sie ermöglicht das Melden von Schwachstellen, das Eingestehen von Unsicherheiten und das Teilen von Verbesserungsvorschlägen.

Typische Merkmale psychologisch sicherer Teams:

- Offene Kommunikation ohne Angst vor Blamage
- Gegenseitiger Respekt, auch in Stresssituationen
- Aktives Zuhören und wertschätzendes Feedback
- Fehlermeldungen werden als Beitrag, nicht als Kritik verstanden

Ohne psychologische Sicherheit bleibt jede Resilienzinitiative oberflächlich.

9.3 Blame-free Post-Mortems und After-Action Reviews

Nach jedem Incident oder jeder Übung sollten strukturierte Reflexionssitzungen stattfinden.

Bewährt hat sich das Konzept der **blame-free Post-Mortems**, ursprünglich aus der Luftfahrt und heute Standard im DevOps- und Cyberbereich.

Typische Leitfragen:

1. Was ist passiert – objektiv und ohne Schuldzuweisung?
2. Warum ist es passiert – welche Faktoren haben beigetragen?
3. Wie haben wir reagiert – was hat geholfen, was behindert?
4. Was lernen wir daraus – und wie setzen wir das um?

Diese Besprechungen sind kein Ritual, sondern ein **organisationaler Lernprozess**. Wichtig ist, dass Ergebnisse dokumentiert, priorisiert und tatsächlich umgesetzt werden – sonst wird aus Lernen schnell Symbolpolitik.

9.4 Führung als Kulturträger

Kultur entsteht nicht durch Leitbilder, sondern durch Verhalten. Führungskräfte prägen Resilienz durch das, **was sie in Krisen tun – und was sie zulassen.**

Offene Fehlerkommunikation von oben schafft Vertrauen unten.

Führung in resilienten Organisationen bedeutet:

- Informationsfluss fördern, nicht kontrollieren
- Lernräume schaffen, nicht Schuldige suchen

- Fehler öffentlich reflektieren, um Nachahmung zu fördern
- Positives Feedback bei transparenter Kommunikation geben

Resiliente Führung ist damit ein Balanceakt zwischen **Kontrolle und Vertrauen**.

9.5 Vom Lernen zur Evolution

Resilienz ist kein Zielzustand, sondern eine Entwicklungsrichtung. Organisationen, die regelmäßig reflektieren, adaptieren und neu justieren, verwandeln sich in **adaptive Systeme**, die mit Unsicherheit leben können. Das ist die höchste Stufe des Reifegrads: Nicht nur *robust*, sondern *lernend* zu sein.

„Eine resiliente Organisation ist nicht unverwundbar – sie ist lernfähig genug, Verwundbarkeit zu überstehen."

Kernaussage:

Kultur ist der Katalysator der Resilienz. Wo Menschen ohne Angst kommunizieren und Fehler als Lernquelle sehen, wird Resilienz Teil der DNA einer Organisation.

Kapitel 10 – Zusammenfassung und Ausblick: Von der Reaktion zur Steuerung organisationaler Resilienz

Organisationale Resilienz ist weit mehr als Krisenmanagement. Sie beschreibt die Fähigkeit einer Organisation, unter Stress **koordiniert zu handeln, zu lernen und sich weiterzuentwickeln**.

Damit ist sie der zentrale Unterschied zwischen **reaktiver Schadensbegrenzung** und **strategischer Anpassungsfähigkeit**.

10.1 Kernerkenntnisse der Sitzung

1. **Resilienz ist Verhalten, nicht Dokumentation.**

   Strukturen, Prozesse und Playbooks sind wichtig, aber entscheidend ist, *wie* Menschen sie unter Druck umsetzen.

2. **Kommunikation ist der Dreh- und Angelpunkt.**

   Klare Sprache, definierte Kanäle und gegenseitiges Verständnis sind der Klebstoff, der Organisationen im Ereignisfall zusammenhält.

3. **Rollen schaffen Ordnung im Chaos.**

   Wenn Verantwortlichkeiten und Eskalationspfade klar sind, kann auch in komplexen Lagen schnell und sicher entschieden werden.

4. **Übung macht Resilienz.**

   Tabletop-Trainings und Simulationen sind das Labor für reale Handlungsfähigkeit.

   Nur wer trainiert, reagiert im Ernstfall strukturiert.

5. **Kultur entscheidet über Nachhaltigkeit.**

   Psychologische Sicherheit, offene Fehlerkommunikation und Lernprozesse sind die kulturellen Grundlagen dauerhafter Anpassungsfähigkeit.

6. **Governance verankert Resilienz.**

   Erst durch Managementsysteme, Audits und Reifegradbewertung wird Resilienz von einer Initiative zu einer messbaren Fähigkeit.

10.2 Von der Reaktion zur Steuerung

Im Reifeprozess resilienter Organisationen lässt sich ein klarer Übergang erkennen:

Phase	Fokus	Beispiel
Reaktion	Ad-hoc-Antwort auf Störungen	Incident Handling, Krisenteams
Koordination	Standardisierte Verfahren	Playbooks, Kommunikationsprotokolle
Lernen	Feedback und Verbesserung	After-Action Reviews
Steuerung	Integration in Governance	KPIs, Audits, Management Reviews

Resilienz entwickelt sich damit von einer *Einsatzfähigkeit* zu einer *Führungsdisziplin*.

10.3 Der Blick nach vorn

Die nächste Sitzung widmet sich der Frage:

„Wie lässt sich Resilienz messen, steuern und nachweisen?“

Damit rückt die **Quantifizierung und Operationalisierung** in den Mittelpunkt:

- Welche Kennzahlen bilden Resilienz sinnvoll ab?
- Wie misst man organisatorische Reaktionsgeschwindigkeit und Lernfähigkeit?
- Welche Instrumente (Dashboards, Audits, Maturity Models) unterstützen die Steuerung?

Diese Brücke führt von der gelebten Praxis zur messbaren Managementfähigkeit – und schließt damit den Bogen von der *reaktiven* zur *proaktiven Resilienz*.

10.4 Fazit

„Technik stabilisiert Systeme – Organisation stabilisiert Verhalten – Kultur stabilisiert Vertrauen.“

Das Zusammenspiel dieser drei Ebenen definiert die **Gesamtresilienz** einer Organisation. Sobald sie ineinandergreifen, entsteht die Fähigkeit, auch unter widrigen Bedingungen handlungsfähig zu bleiben – das eigentliche Ziel jedes Resilienzmanagements.

Bibliografie

[1] A. Nelson, S. Rekhi, M. Souppaya, und K. Scarfone, „Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile“, NIST Special Publication 800-61 Rev. 3, Apr. 2025. doi: 10.6028/NIST.SP.800-61r3.

[2] „BSI-Standard 200-4: Business Continuity Management“. Bonn, Mai 2023.